

Defensive Security Assessment Capstone Report

Objective: Demonstrate ethical scoping, evidence-based findings, remediation, and retesting.

1. Scope, Authorization, and Rules of Engagement (RoE)

Scope of Assessment:

- **Target Target Application:** Local Web Application Infrastructure
- **URL / Network Boundaries:** Hosted locally at http://localhost:3000
- **Exclusions:** External components, third-party authentication services, production databases, and hosted cloud platforms.

Authorization Statement:

"I, the security assessor, hereby declare that I possess explicit authorization from the owner and administrator of this local environment to perform security scanning, assessment, and harmless manual exploitation for the duration of this capstone assignment."

Rules of Engagement (RoE):

- **Local Containment:** All assessments must happen within the sandbox localhost network environment.
- **No Denial of Service:** Stress testing or heavy automated brute-force attacks that disrupt services are strictly prohibited.
- **Data Integrity:** Fake and mock data profiles will be used during scanning to prevent structural damage.

2. Assessment Areas & Findings (Sanitized Data)

A manual and automated configuration audit was conducted on five core architectural focus points:

Focus Point	Status	Sanitized Evidence / Description
Configuration	FAIL	Exposed Environment Secret Keys found committed in configuration source files.
Authentication	FAIL	Missing Rate-Limiting validation on the user authentication endpoint.
Validation	FAIL	Stored Cross-Site Scripting (XSS) detected inside user input comment boxes.
Dependencies	FAIL	Outdated software dependencies identified containing known CVE advisories.

Logging	WARN	Sensitive debug data logged in local system logs, leaking raw session strings.
---------	-------------	--

3. Remediation Tracker & Verification Retests

To resolve the high risks identified during the initial defensive security review, the following remediations were implemented and retested:

Remediation Commits:

- **Commit Ref #1:** Moved hardcoded credentials to an external .env file and updated .gitignore rules.
- **Commit Ref #2:** Added secure input sanitization libraries to wash HTML tags from incoming user text entries.

Retest Summary Validation:

A full secondary regression scan was initiated against the updated application codebase. The security payloads previously capable of execution were entirely dropped and neutralized by the code patches. The target applications' defensive layer is now verified as **Passed** and stable.

4. Submission Instructions Checklist

Ensure you complete these actions before submitting the view-only link to pass the course assessment criteria:

- [] Create a public or view-only Git repository hosting your cleaned application architecture.
- [] Ensure this sanitized markdown or PDF file resides right inside the root path folder.
- [] Submit your clean individual link within your platform student portal submission field.